

HW06 API Testing Report

Submission identity and scope

- Student ID: 23127414
- SUT: ttbhanh/eshop-sut at commit 85af3ba875c88283615e22cb108f13e2fccaf0e9
- Tools: Postman and Newman 6.2.2
- Required attribution: collection-level script inserts and logs X-Student-Id: 23127414
- Selected features: FR-01 Account Registration, FR-11 User Order History, and all four FR-14 Category CRUD endpoints

Coverage and execution summary

```
| Endpoint | AI | Human | Cases | Requests | Assertions passed | Assertions failed | Failing cases | Defect candidates |
| --- | ---: | ---: | ---: | ---: | ---: | ---: | ---: | ---: |
| POST /api/register | 40 | 5 | 45 | 155 | 54 | 30 | 29 | 4 |
| GET /api/orders/my-orders | 40 | 7 | 47 | 71 | 35 | 14 | 14 | 5 |
| GET /api/categories | 40 | 6 | 46 | 75 | 47 | 1 | 1 | 1 |
| POST /api/categories | 40 | 7 | 47 | 93 | 32 | 25 | 25 | 5 |
| PUT /api/categories/:id | 40 | 7 | 47 | 75 | 30 | 29 | 29 | 6 |
| DELETE /api/categories/:id | 40 | 7 | 47 | 116 | 49 | 37 | 24 | 6 |
| Total | 240 | 39 | 279 | 585 | 247 | 136 | 122 | 27 |
```

The 279-case interpretation follows the student's explicit decision that the minimum applies independently to every endpoint. Seven FR-11 setup items are excluded from case counts but their HTTP requests are included in execution totals.

Human audit summary

```
| Endpoint | VALID | INVALID and corrected | INCOMPLETE observation | Total AI cases |
| --- | ---: | ---: | ---: | ---: |
| FR-01 Register | 33 | 3 | 4 | 40 |
| FR-11 Order History | 36 | 2 | 2 | 40 |
| FR-14 GET | 34 | 0 | 6 | 40 |
| FR-14 POST | 38 | 0 | 2 | 40 |
| FR-14 PUT | 38 | 0 | 2 | 40 |
| FR-14 DELETE | 40 | 0 | 0 | 40 |
| Total | 219 | 5 | 16 | 240 |
```

Invalid AI cases were corrected during human review before implementation. Incomplete cases were executed only as observations and did not independently establish defects.

Principal findings

1. Registration lacks server-side name, email, and password validation; duplicate emails are accepted; credentials are exposed in plaintext; parser errors disclose internal paths.
2. Order history exposes fields outside the approved schema, accepts malformed authorization schemes, authorizes deleted principals, trusts semantically invalid JWT claims, and is exploitable with the hard-coded signing secret.
3. Category GET meets almost all selected behavior but ignores the approved Accept: text/html → 406 rule.
4. Category POST and PUT do not validate or normalize names and do not enforce admin-only authorization.
5. Category PUT and DELETE report success for nonexistent or malformed IDs because affected-row counts are not checked.
6. Category DELETE permits orphaned products and ignores forbidden body/media input.

Detailed evidence, affected IDs, actual/expected results, and severity proposals are in each endpoint's execution-results.md and in docs/bug-summary.md.

Reproducibility controls

- The SUT is pinned to a full commit SHA.
- Stateful cases use deterministic SQLite fixtures prepared only after server startup.
- Cardinality-sensitive GET/DELETE cases run in separate fixture modes.
- Database backups are stored outside the submission repo and restored after every run.
- Generated Postman scripts are compiled before execution where possible.
- One invalid POST harness run was rejected, corrected, reset, and rerun; it is not included in totals.
- HTML Newman reports are committed; raw JSON stays under the local .runtime diagnostics directory.

CI and Agent Skill

- CI contains a small known-good smoke collection so genuine full-suite conformance failures are not relabeled as passing behavior.

- Public pass/fail run links are recorded in docs/ci-evidence.md, and the final branch is restored to green.
- agent-skill/audited-api-test-workflow packages the audit and evidence process. Its structure and scripts were validated against this submission.

Remaining student-owned evidence

The following cannot be fabricated by automation and must be completed by the student:

- draw the required test-generator diagram personally;
- record the Agent Skill demonstration video;
- capture GitHub Issue/Newman/CI screenshots through a connected browser and attach them to the relevant issues;
- select the final self-assessed grade after checking the official rubric.

Confirmed Defect Candidate Summary

ID	Endpoint	Finding	Proposed severity
---	---	---	---
BUG-FR01-001	Register	Missing server-side field validation	High
BUG-FR01-002	Register	Email uniqueness not enforced atomically	High
BUG-FR01-003	Register/Login	Plaintext password storage/exposure	Critical
BUG-FR01-004	Register	Parser stack disclosure and wrong media status	High
BUG-FR11-001	Order history	Response violates strict/minimized schema	Medium
BUG-FR11-002	Order history	Authorization scheme parsing is inconsistent	High
BUG-FR11-003	Order history	Deleted/nonexistent principals remain authorized	High
BUG-FR11-004	Order history	Hard-coded signing secret enables forged-token IDOR	Critical
BUG-FR11-005	Order history	JWT claims lack semantic validation	High
BUG-FR14GET-001	Category GET	Unacceptable HTML media is ignored	Low
BUG-FR14POST-001	Category POST	Name validation/normalization/extra-field policy absent	High
BUG-FR14POST-002	Category POST	Parser/media errors disclose internals or return 500	High
BUG-FR14POST-003	Category POST	Admin authorization not enforced	Critical
BUG-FR14POST-004	Category POST	Empty Authorization classified incorrectly	Low
BUG-FR14POST-005	Category POST	Unacceptable response media is ignored	Low
BUG-FR14PUT-001	Category PUT	Name validation/normalization/extra-field policy absent	High
BUG-FR14PUT-002	Category PUT	Parser/media errors disclose internals or return 500	High
BUG-FR14PUT-003	Category PUT	Invalid/nonexistent IDs falsely report success	Medium
BUG-FR14PUT-004	Category PUT	Admin authorization not enforced	Critical
BUG-FR14PUT-005	Category PUT	Empty Authorization classified incorrectly	Low
BUG-FR14PUT-006	Category PUT	Unacceptable response media is ignored	Low
BUG-FR14DELETE-001	Category DELETE	ID coercion and affected-row checks allow false/unintended deletion	High
BUG-FR14DELETE-002	Category DELETE	Admin authorization not enforced	Critical
BUG-FR14DELETE-003	Category DELETE	Referenced category deletion creates orphan products	High
BUG-FR14DELETE-004	Category DELETE	Unexpected bodies/media are ignored	Medium
BUG-FR14DELETE-005	Category DELETE	Empty Authorization classified incorrectly	Low
BUG-FR14DELETE-006	Category DELETE	Unacceptable response media is ignored	Low

These 27 entries are endpoint-attributable candidates. Related root causes may be linked across GitHub Issues, but evidence and affected test IDs remain in the endpoint execution reports.

AI Critique

AI was most useful for breadth and mechanical consistency. It quickly partitioned inputs, authentication states, media types, concurrency, schemas, and injection payloads across six endpoints. It also helped generate repeatable Postman scripts and fixtures, which made 279 cases practical. However, the initial output was not trustworthy without human review. Five generated cases were invalid because they contradicted the chosen schema or mixed two concerns, and sixteen were incomplete because the requirements did not define a boundary, cache rule, recovery behavior, or performance threshold.

The most important human contribution was establishing explicit oracles. Decisions about case-sensitive email uniqueness, strict response fields, 400/401/403/404/406/409/415 statuses, whitespace trimming, duplicate category names, extra fields, and referenced-category deletion changed the meaning of many tests. Without those choices, AI could have produced apparently precise but fabricated failures. Human-added tests also found deeper risks that the first generation missed, particularly forged JWTs using the hard-coded secret, semantic claim validation, response-header injection, token smuggling, lifecycle races, and referential integrity.

AI also introduced a concrete harness defect: four duplicate-workflow scripts had invalid parentheses. That first POST run was discarded, the scripts were compiled, the fixture was reset, and the suite was rerun. This demonstrates why generated tests themselves require validation. Overall, AI substantially increased coverage and documentation speed, while human judgment remained responsible for requirements interpretation, defect legitimacy, and evidence quality. The safest workflow is therefore generation, explicit audit, deterministic execution, and root-cause review—not direct acceptance of generated cases.

GitHub Actions CI Evidence

Workflow

- Workflow: API smoke
- SUT: teacher repository pinned to commit 85af3ba875c88283615e22cb108f13e2fccaf0e9
- Runner: Ubuntu with Node.js 22 and Newman 6.2.2
- Attribution: collection pre-request script logs X-Student-Id: 23127414 for every request
- Scope: a separate three-request smoke collection proves the CI harness. The full audited contract collection intentionally retains confirmed SUT failures and is not relabeled as passing behavior.

Required pass/fail history

Purpose	Commit	Run	Result
---	---	---	---
Initial all-pass run	2aa67f6	[GitHub Actions run 33666325233](https://github.com/luanthu11/hw06-api-testing/actions/runs/33666325233)	Success
Intentional one-fail demonstration	ee9c636	[GitHub Actions run 33708693475](https://github.com/luanthu11/hw06-api-testing/actions/runs/33708693475)	Failure
Final restored run	eb779bd	[GitHub Actions run 33708895230](https://github.com/luanthu11/hw06-api-testing/actions/runs/33708895230)	Success

The failing commit changed only ciExpectedStatus from 200 to 418. Therefore CI-001 produced one intentional assertion failure while the remaining smoke assertions stayed valid. The next commit restored 200, and the final public run confirms that the repository returned to green.

Real UI screenshots remain pending because no connected interactive browser is available in the current environment. The immutable public run URLs above are preserved for verification and later screenshot capture.